

Launch Readiness & Security Checklist

What's already done, and what to check before MyAccentTrainer goes live

MyAccentTrainer is feature-complete — the whole learner experience, coaching, payments, referrals, admin, and content management are built and pass a clean type-check. This checklist covers the last mile: the operational and security steps between "built" and "safely live for real users."

It's written so you can read it yourself, and hand it to any developer as a to-do list. Each item says plainly **who does it** — some are already done, some need your accounts, a few are worth a developer's eye.

Already hardened (done for you)

These are in the code now, verified:

- **Secure sessions.** Logins use signed tokens stored in HTTP-only cookies (not readable by scripts), marked secure in production. Passwords are hashed with bcrypt — never stored in plain text.
 - **Security headers.** Every response sends modern protections (clickjacking, content-type sniffing, referrer, and permissions policies). The microphone stays enabled for the practice recorder; everything else is locked down.
 - **Rate limiting.** Login, sign-up, and password-reset are throttled so someone can't hammer them with automated guesses.
 - **Input validation.** Every form and API validates its input before doing anything with it.
 - **A secret guard.** If the app is ever started in production without its security key set, it logs a loud warning so the mistake can't go unnoticed.
 - **A health check.** A monitoring endpoint at `/api/health` reports whether the app and database are responding — ready to plug into any uptime service.
 - **Keyless-safe integrations.** Payments, speech, and email all run in a safe "not configured yet" mode until you add keys, so nothing breaks or leaks before you're ready.
-

The launch checklist (what remains)

1. Turn on the database — *you, ~15 min*

Follow the deployment guide's Part C to switch from the local database to a hosted one, then run the one-time setup so every table from the recent features is created. Until this runs, the new features (Nina's memory, coaching goals, favorites, recordings, referrals, content) store nothing.

2. Add your live keys — *you, ~20 min*

In your hosting settings, add: a long random **JWT_SECRET** (required), your **Stripe** live keys and price IDs (to take real payments), a **RESEND_API_KEY** (to actually send verification, reset, and invite emails), and optionally your **Azure Speech** keys (for exact per-sound scoring instead of the built-in estimate). Every one of these is optional to *launch* except the JWT secret — you can switch payments and email on whenever you're ready.

3. Database backups — *you / your host, ~10 min*

Turn on automated backups with your database provider (Prisma Postgres, Neon, and Supabase all offer this). This is a one-click setting on most hosts and protects your users' data.

4. Monitoring — *you, ~15 min*

Point a free uptime service (such as UptimeRobot or Better Stack) at `/api/health`. It'll alert you if the site ever goes down. Your hosting dashboard also shows errors and traffic automatically.

5. Security review — *a developer, ~1-2 hrs*

Worth a technical pass before real users arrive: add a Content-Security-Policy (intentionally left off for now so it can be tuned against the live site without breaking anything), run a dependency audit (`npm audit`), and confirm no secrets are committed to the code repository. None are today — this is a "keep it that way" check.

6. Load testing — *a developer, ~1 hr*

Once live, a quick load test (k6 or Artillery) confirms the app stays responsive under many simultaneous users. Only meaningful after deployment, so this comes near the end.

7. Reaching phones — *later, optional*

MyAccentTrainer is a website, so it already works in any phone browser. To appear in the App Store and Google Play, the usual path is to make it an installable web app (a small, well-trodden addition) or wrap it — a project to take on once you have traction, not a launch blocker.

The honest bottom line

The product is built. Steps 1 and 2 above — a hosted database and your keys — are all that stand between today and a **live link you can share and take payments on**. Everything else on this list makes launch *safer and sturdier*, and can follow in the days after you go live.

You've done the hard part. This last mile is well-mapped, and everything you need — this checklist, the deployment guide, and the prepared `deploy/` files — is already in your hands.